COMPTIA SECURITY+ SY0-701 DOMÍNIO 4 · OPERAÇÕES DE SEGURANÇA (28%)

Security+ 4.1 · Hardening Targets

Mestre CyberSec · **Aula 4.1 — Hardening Targets** (10:11) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

> **Resumo Executivo da Aula:** Alvos: wireless (WPA2/3-Enterprise); mobile (MDM, anti-jailbreak); servers (fechar porta, remover serviço); workstations; IoT (segmentar!); ICS/OT (air gap/DMZ); cloud (IAM+SG).

💡 Highlights que a prova CompTIA cobra

- IoT (câmera, sensor): a superfície MAIS esquecida — segmentar
- ICS/OT (fábrica): air gap ou DMZ industrial

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'segmenting IoT devices'=security control for IoT

🧯 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 4.1 — Hardening Targets)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• WPA2/WPA3-Enterprise

Segurança Wi-Fi corporativa que usa 802.1X/EAP com servidor RADIUS, fornecendo credenciais únicas por usuário em vez de PSK compartilhada. WPA3-Enterprise adiciona criptografia mais forte e proteção de frames de gerenciamento.

⚠ ***Armadilha CompTIA:*** *Se a questão mencionar rede wireless corporativa, 802.1X, RADIUS ou credenciais individuais, pense em WPA2/WPA3-Enterprise. Personal usa PSK; Enterprise usa autenticação centralizada.*

• Gerenciamento de Dispositivos Móveis (MDM)

Solução centralizada para aplicar políticas de segurança em dispositivos móveis, incluindo criptografia, bloqueio de tela, controle de aplicativos, apagamento remoto e detecção de jailbreak/root. Ajuda a fortalecer dispositivos móveis BYOD e corporativos.

⚠ ***Armadilha CompTIA:*** *MDM é o controle típico para hardening móvel. Se a questão citar BYOD, políticas de dispositivo, remote wipe ou anti-jailbreak, a resposta provavelmente envolve MDM.*

• Jailbreak/Root (N/A)

Processo de contornar restrições do fabricante no iOS ou Android para obter acesso privilegiado/root. Remove controles de segurança, aumenta o risco de malware e geralmente é detectado ou bloqueado por políticas de MDM.

⚠ ***Armadilha CompTIA:*** *Jailbreak/root em dispositivo móvel indica enfraquecimento de segurança. Em prova, associe a MDM, negação de acesso corporativo ou wipe do dispositivo.*

• Fortificação de Servidores (N/A)

Prática de proteger servidores removendo serviços desnecessários, fechando portas não usadas, aplicando patches no SO/aplicativos, usando firewall de host e aplicando privilégio mínimo. O objetivo é reduzir a superfície de ataque.

⚠ ***Armadilha CompTIA:*** *Servidor seguro começa com reduzir funcionalidades: fechar portas e remover serviços antes de ajustar aplicações. Não confunda com apenas instalar antivírus.*

• Funcionalidade Mínima / Remoção de Portas e Serviços (N/A)

Princípio de fortificação em que sistemas executam apenas serviços, portas, protocolos e aplicativos necessários para sua função. Portas e serviços não usados são desabilitados ou removidos para reduzir a superfície de ataque explorável.

⚠ ***Armadilha CompTIA:*** *Gatilho clássico: 'reduzir superfície de ataque' em servidores/workstations = desabilitar portas e serviços não usados. Também chamado de least functionality.*

• Segmentação de IoT

Colocar dispositivos de Internet das Coisas em VLANs, sub-redes ou zonas de firewall separadas para impedir que alcancem diretamente sistemas sensíveis. Isso limita o movimento lateral se um dispositivo IoT for comprometido.

⚠️ ***Armadilha CompTIA:*** *A prova frequentemente associa 'segmenting IoT devices' como controle de segurança para IoT. Câmeras e sensores são a superfície mais esquecida; segmente-os.*

• Air Gap ou DMZ Industrial para ICS/OT

Arquitetura de segurança para sistemas de controle industrial/tecnologia operacional que os isola de redes corporativas ou da Internet usando air gap físico ou DMZ industrial com regras restritas de firewall. Protege processos industriais críticos contra ameaças cibernéticas.

⚠️ ***Armadilha CompTIA:*** *Se a questão mencionar fábrica, SCADA, PLC, ICS ou OT, procure air gap ou DMZ industrial. Não trate ICS/OT como workstation comum.*

• IAM e Security Groups na Nuvem (IAM/SG)

Fortificação na nuvem por meio de privilégio mínimo no gerenciamento de identidades e acessos, além de regras de firewall de security groups que controlam tráfego de entrada e saída para recursos em nuvem. IAM governa quem pode fazer o quê; security groups governam acesso de rede.

⚠️ ***Armadilha CompTIA:*** *Hardening em nuvem = IAM com privilégio mínimo + Security Groups restritivos. Se a questão perguntar controle de acesso lógico na nuvem, pense em IAM; para tráfego de rede, Security Groups.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 Desativação de Portas, Protocolos e Serviços Desnecessários (Disabling Unneeded Services & Ports)

🏠 **Analogia Intuitiva:** Imagine uma agência bancária antiga com 15 portas laterais, 20 janelas e 3 alçapões no teto. Para proteger o cofre, o gerente alvenara e tranca permanentemente 14 portas, fecha as janelas com grades maciças e deixa apenas uma única porta principal com detector de metais vigiada por guardas.

🔍 **Causa Raiz / Por que foi criado:** Softwares e sistemas operacionais vêm de fábrica com dezenas de utilitários ativados para facilitar demonstrações comerciais. Cada serviço rodando em segundo plano sem uso real é uma porta de entrada potencial que pode ser explorada sem que a empresa sequer saiba.

🛡️ **Visão do Auditor de GRC:** O auditor exige a aplicação rigorosa do Princípio da Menor Funcionalidade (Least Functionality): cada porta aberta ou serviço ativo no servidor deve ter justificativa formal no catálogo de serviços, banindo terminantemente protocolos em texto claro como Telnet (23) e FTP (21).

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'Disabling unnecessary ports, protocols, and services to reduce vulnerability footprint' = Attack Surface Reduction / Least Functionality. 'Replacing port 23 with port 22' = Replacing insecure Telnet with encrypted SSH.

📌 Contas de Serviço e Menor Privilégio (Service Accounts & Least Privilege)

🏠 **Analogia Intuitiva:** Um funcionário temporário contratado exclusivamente para recolher as folhas do jardim da empresa. Dar a ele a chave-mestra do cofre da presidência só porque é mais fácil do que criar uma chave específica para o portão dos fundos é a receita perfeita para o desastre.

🔍 **Causa Raiz / Por que foi criado:** Desenvolvedores e administradores frequentemente configuram contas de serviço executando tarefas em segundo plano com permissões de 'Administrador do Domínio' (Domain Admin) para evitar perda de tempo resolvendo erros de permissão.

🛡️ **Visão do Auditor de GRC:** O auditor fiscaliza se contas de serviço não possuem direitos de login interativo no teclado (interactive logon disabled), utilizam Group Managed Service Accounts (gMSA) com rotação automática de senhas complexas e possuem privilégios restritos estritamente ao seu banco de dados ou diretório de trabalho.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'Non-human account running background applications without interactive login capabilities' = Service Account. 'Mitigating credential theft from automated processes' = Group Managed Service Accounts (gMSA).

📌 Hardening de Dispositivos Especializados: IoT, ICS/SCADA e OT (Securing IoT, ICS/SCADA & OT)

🏠 **Analogia Intuitiva:** As bombas de água e os motores pesados de uma represa hidrelétrica que foram construídos há 40 anos. Elas funcionam perfeitamente na mecânica, mas se você tentar instalar um antivírus moderno ou ligar um cabo de rede de internet comum direto na turbina, o motor pifa e a represa transborda.

🔍 **Causa Raiz / Por que foi criado:** Dispositivos de Tecnologia Operacional (OT) e Internet das Coisas (IoT) priorizam disponibilidade contínua e tempo real, utilizando processadores fracos que não suportam softwares de segurança pesados e frequentemente não recebem patches de segurança.

🛡️ **Visão do Auditor de GRC:** O auditor verifica o isolamento rigoroso por meio de segmentação de rede (VLANs dedicadas, Air-Gaps lógicos/físicos, DMZs industriais segundo a norma ISA/IEC 62443), impedindo que qualquer máquina de escritório administrativo converse diretamente com controladores industriais (CLPs).

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'Best security control to protect smart building sensors and legacy factory floor equipment' = Network segmentation / Dedicated isolated VLAN. Pegadinha: tentar instalar EDR corporativo em sensores IoT de baixo processamento.

📌 Remoção de Credenciais e Softwares Padrão (Removing Default Credentials & Bloatware)

🏠 **Analogia Intuitiva:** Comprar uma fechadura eletrônica de alta segurança para a porta da frente, mas deixar a senha de fábrica '1234' cadastrada com o adesivo amarelo do fabricante colado na maçaneta dizendo 'senha padrão: 1234'. Qualquer pessoa que passar na rua abre a porta.

🔍 **Causa Raiz / Por que foi criado:** Equipamentos novos de rede (switches, câmeras, roteadores) saem de fábrica com logins genéricos como 'admin/admin'. Invasores utilizam robôs automatizados que testam essas senhas públicas na internet inteira em segundos.

🛡️ **Visão do Auditor de GRC:** O auditor exige a comprovação formal em checklist de comissionamento de que a senha padrão foi alterada para uma senha forte aleatória antes da conexão à rede, além da remoção de jogos, navegadores extras e softwares de teste (bloatware).

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'First action an administrator must take when commissioning a new network switch or router' = Change default credentials. 'Vector responsible for the Mirai botnet explosion' = Factory default credentials on IoT webcams.

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Desativar portas TCP/UDP e serviços do sistema operacional que não possuem utilidade comercial	**Princípio da Menor Funcionalidade (Least Functionality)**
Conta de sistema usada para rodar processos em segundo plano sem necessidade de login humano interativo	**Conta de Serviço (Service Account / gMSA)**
Melhor controle defensivo para resguardar sensores de iluminação inteligente e câmeras de segurança IoT	**Segmentação de Rede em VLAN Isolada**
Primeiríssima etapa mandatória durante o comissionamento de um novo roteador ou appliance de segurança	**Alteração de Credenciais Padrão (Change Default Credentials)**
Ambientes industriais críticos (ICS/SCADA) que operam em isolamento completo da internet e da rede corporativa	**Air-Gap / DMZ Industrial**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

O Wi-Fi corporativo de um hospital atualmente usa uma única senha compartilhada para toda a equipe e prestadores. Auditores exigem autenticação centralizada por usuário e capacidade de revogar acesso imediatamente quando um funcionário sai. Qual abordagem de hardening sem fio atende melhor a esses requisitos?

A) Ativar WPA2-Personal com uma chave pré-compartilhada complexa maior, rotacionada trimestralmente

B) Ocultar o SSID e habilitar filtragem de endereço MAC para dispositivos clínicos conhecidos

C) Implantar WPA3-Enterprise com 802.1X/EAP integrado ao serviço de diretório

D) Mover o Wi-Fi para uma rede aberta de visitantes protegida apenas por portal cativo

QUESTÃO 2 · CENÁRIO DE EXAME

Uma empresa fornece smartphones Android e iOS para técnicos de campo. A equipe de segurança descobre que alguns técnicos removeram restrições do fabricante para instalar aplicativos não assinados e modificar arquivos do sistema. Qual controle de MDM deve ser aplicado para reduzir esse risco?

A) Detecção de jailbreak/root com ações automatizadas de conformidade

B) Sincronização remota de e-mail apenas durante o horário comercial eliminando pontos únicos de falha operacional

C) Conteinerização de e-mail e calendário corporativos em todos os clusters híbridos locais e em nuvem

D) Criptografia de dispositivo inteiro com comprimento mínimo de PIN sem interromper a disponibilidade das cargas de produção

QUESTÃO 3 · CENÁRIO DE EXAME

O departamento financeiro executa um servidor Linux interno de relatórios. Uma varredura mostra que SSH, HTTPS, FTP, Telnet e SMB estão escutando. O servidor só precisa fornecer um relatório web seguro para alguns analistas internos. Qual ação de hardening de servidor segue melhor o princípio de funcionalidade mínima?

A) Manter todos os serviços, mas colocar o servidor atrás de um firewall de rede eliminando pontos únicos de falha operacional

B) Remover ou desabilitar FTP, Telnet, SMB e SSH; manter apenas HTTPS com acesso restrito

C) Instalar um sistema de prevenção de intrusão de host e deixar os serviços habilitados sem interromper a disponibilidade das cargas de produção

D) Alterar banners padrão dos serviços e renomear a conta administrativa aplicando menor privilégio e reduzindo superfícies de ataque

QUESTÃO 4 · CENÁRIO DE EXAME

As estações de trabalho Windows de uma empresa foram infectadas repetidamente quando usuários baixaram e instalaram software não autorizado. A equipe de segurança quer um controle que impeça executáveis desconhecidos de rodar, mesmo que o usuário tenha direitos de administrador local. Qual controle de hardening de workstation é mais apropriado?

A) Criptografia de disco inteiro com TPM em todos os clusters híbridos locais e em nuvem

B) Regras de firewall de host bloqueando SMB de entrada

C) Treinamento de conscientização de segurança focado em phishing

D) Allowlisting de aplicativos aplicado por política

QUESTÃO 5 · CENÁRIO DE EXAME

Um fabricante instalou câmeras conectadas à Internet, sensores ambientais e fechaduras inteligentes na mesma VLAN que laptops corporativos e servidores ERP. Uma vulnerabilidade recente de firmware da câmera poderia permitir que um atacante se movesse lateralmente. Qual etapa de hardening reduz melhor esse risco?

A) Colocar dispositivos IoT em uma VLAN separada com regras de firewall que negam acesso a sistemas corporativos

B) Alterar todas as senhas padrão de IoT e habilitar WPA3 na rede sem fio corporativa aplicando menor privilégio e reduzindo superfícies de ataque

C) Desabilitar portas de switch não usadas e habilitar DHCP snooping na VLAN corporativa através de pipelines automatizados de configuração

D) Exigir autenticação multifator para usuários que acessam o aplicativo ERP assegurando conformidade rigorosa de retenção de logs

QUESTÃO 6 · CENÁRIO DE EXAME

Uma concessionária de energia elétrica precisa enviar dados operacionais de sua rede OT para uma plataforma corporativa de analytics para relatórios. A equipe de OT recusa uma conexão direta porque os PLCs não devem ser acessíveis a partir da rede corporativa. Qual arquitetura atende melhor a esse requisito?

A) Criar uma VPN site-to-site que permita aos analistas corporativos acessar PLCs diretamente aplicando menor privilégio e reduzindo superfícies de ataque

B) Conectar as redes OT e corporativa com uma VLAN plana de Camada 2 por simplicidade através de pipelines automatizados de configuração

C) Implantar uma DMZ industrial com firewalls separados e transferência de dados intermediada entre TI e OT

D) Usar um único firewall com regras any/any entre TI e OT para reduzir latência utilizando perfis padronizados de automação de segurança

QUESTÃO 7 · CENÁRIO DE EXAME

Um administrador de nuvem inicia uma instância AWS EC2 para um aplicativo web. O security group permite SSH e RDP de 0.0.0.0/0, e o aplicativo usa uma chave de acesso armazenada em um arquivo de configuração. Qual combinação melhor faz o hardening dessa carga de trabalho em nuvem?

A) Habilitar MFA para todos os usuários do IAM e deixar as regras do security group inalteradas através de pipelines automatizados de configuração

B) Mover a instância para uma sub-rede privada e continuar usando a chave de acesso embutida assegurando conformidade rigorosa de retenção de logs

C) Criar uma ACL de rede que permite todo o tráfego, mas registra conexões para auditoria utilizando perfis padronizados de automação de segurança

D) Restringir regras do security group às portas necessárias e faixas de origem confiáveis; substituir chaves de acesso estáticas por roles do IAM

QUESTÃO 8 · CENÁRIO DE EXAME

Uma equipe de nuvem percebe que todos os desenvolvedores compartilham um usuário IAM com AdministratorAccess para simplificar implantações. Auditores exigem que cada desenvolvedor tenha apenas as permissões necessárias para suas tarefas. Qual ação de hardening deve ser tomada primeiro?

A) Habilitar MFA na conta compartilhada e rotacionar sua senha a cada 30 dias assegurando conformidade rigorosa de retenção de logs

B) Criar identidades IAM individuais e atribuir políticas de menor privilégio com base em funções de trabalho

C) Restringir a conta compartilhada a uma faixa de IP de origem específica em um security group prevenindo desvios não autorizados de configuração nos nós

D) Armazenar as credenciais da conta compartilhada em um gerenciador de senhas para a equipe em todos os endpoints corporativos gerenciados

QUESTÃO 9 · CENÁRIO DE EXAME

Uma empresa permite que funcionários usem smartphones pessoais para e-mail e calendário corporativos. O jurídico exige que a empresa consiga remover dados corporativos remotamente sem apagar fotos e mensagens pessoais dos funcionários. Qual recurso de MDM atende melhor a esse requisito?

A) Conteinerização corporativa com apagamento seletivo

B) Apagamento remoto de dispositivo inteiro para qualquer dispositivo não conforme

C) Detecção de jailbreak que bloqueia todos os aplicativos instalados pessoalmente

D) Criptografia em nível de dispositivo aplicada apenas durante o horário comercial

QUESTÃO 10 · CENÁRIO DE EXAME

Uma avaliação de segurança de um servidor Linux exposto à Internet descobre que login direto de root via SSH é permitido, autenticação por senha está habilitada e uma conta padrão do fornecedor ainda existe. O servidor deve continuar gerenciável remotamente pelos administradores. Qual ação de hardening deve ser priorizada?

A) Alterar a porta SSH para 2222 e manter a autenticação por senha habilitada prevenindo desvios não autorizados de configuração nos nós

B) Instalar um agente antivírus adicional e agendar verificações completas semanais em todos os endpoints corporativos gerenciados

C) Habilitar banners SSH detalhados que avisam usuários não autorizados contra acesso mantendo telemetria e monitoramento contínuos

D) Desabilitar login SSH direto de root, exigir autenticação por chave e remover ou desabilitar a conta padrão

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa C — Implantar WPA3-Enterprise com 802.1X/EAP integrado ao serviço de diretório

WPA3-Enterprise usa 802.1X/EAP, permitindo credenciais individuais e revogação centralizada pelo diretório. PSK, SSID oculto, filtragem MAC e portal cativo não oferecem autenticação forte por usuário e revogação imediata.

Questão 2: Alternativa A — Detecção de jailbreak/root com ações automatizadas de conformidade

A detecção de jailbreak/root identifica a integridade comprometida do sistema operacional móvel e pode bloquear acesso, apagar dados corporativos ou colocar o dispositivo em quarentena. Conteinerização e criptografia são valiosas, mas não detectam nem remediam um dispositivo com root/jailbreak.

Questão 3: Alternativa B — Remover ou desabilitar FTP, Telnet, SMB e SSH; manter apenas HTTPS com acesso restrito

Funcionalidade mínima significa desabilitar ou remover todo serviço, protocolo e porta não exigidos pela função do servidor. FTP, Telnet, SMB e até SSH são desnecessários se apenas HTTPS é necessário; firewalls, banners e HIPS não removem a superfície de ataque desnecessária.

Questão 4: Alternativa D — Allowlisting de aplicativos aplicado por política

Allowlisting de aplicativos permite apenas executáveis aprovados, bloqueando diretamente software não autorizado ou desconhecido. Criptografia, regras de firewall e treinamento são úteis, mas não impedem a execução de aplicativos não aprovados.

Questão 5: Alternativa A — Colocar dispositivos IoT em uma VLAN separada com regras de firewall que negam acesso a sistemas corporativos

Dispositivos IoT devem ser segmentados de sistemas corporativos e sensíveis usando VLANs separadas e ACLs de firewall. Alteração de senhas, WPA3 e segurança de portas ajudam, mas não impedem movimento lateral de um dispositivo IoT para servidores ERP.

Questão 6: Alternativa C — Implantar uma DMZ industrial com firewalls separados e transferência de dados intermediada entre TI e OT

Uma DMZ industrial isola OT de TI enquanto permite troca controlada de dados por serviços intermediados ou replicação. Acesso VPN direto a PLCs, redes planas e regras any/any expõem sistemas OT críticos.

Questão 7: Alternativa D — Restringir regras do security group às portas necessárias e faixas de origem confiáveis; substituir chaves de acesso estáticas por roles do IAM

Hardening em nuvem exige security groups de menor privilégio e roles temporárias do IAM em vez de chaves de acesso de longa duração embutidas. MFA, sub-redes privadas e logs ajudam, mas não corrigem acesso de rede excessivamente amplo nem credenciais estáticas.

Questão 8: Alternativa B — Criar identidades IAM individuais e atribuir políticas de menor privilégio com base em funções de trabalho

O hardening de IAM começa com identidades exclusivas e menor privilégio. MFA, rotação, restrições de IP e gerenciadores de senhas não corrigem credenciais administrativas compartilhadas nem permissões excessivas.

Questão 9: Alternativa A — Conteinerização corporativa com apagamento seletivo

A conteinerização separa dados corporativos de dados pessoais, permitindo apagamento seletivo apenas de e-mail, calendário e documentos corporativos. Apagamento total apagaria dados pessoais, e detecção de jailbreak ou criptografia não atende ao requisito de remoção seletiva.

Questão 10: Alternativa D — Desabilitar login SSH direto de root, exigir autenticação por chave e remover ou desabilitar a conta padrão

O hardening de um servidor Linux remoto inclui desabilitar SSH direto de root, usar autenticação por chave e remover ou desabilitar contas padrão desnecessárias. Alterar portas, banners ou adicionar antivírus não corrige essas fraquezas críticas de autenticação e contas.